Comprehensive elliptic-curve private-key recovery audit

Charter, evidence contract, and eight-workstream master plan

2026-10-14

Status and outcome

Status: proposed control plane, opened 2026-10-13; first execution checkpoint recorded 2026-10-14. The plan, native planning validator, WS3 identity/canonicalization audit, and draft WS4–WS8 contracts are implemented; the scientific, release, corpus, replication, and review gates governed by the plan are not thereby complete.

This document turns eight accepted next steps into one auditable program. Its near-term product is a common identity, taxonomy, evidence, accounting, and governance layer over the repository's existing specialist ledgers. It does not replace those ledgers and does not promote any mathematical or practical attack claim.

The user's phrase "audit of illicit ECDLP" is retained as the project goal, but the precise scope is an **authorized audit of unauthorized elliptic-curve private-key recovery**. That distinction matters: many real key-recovery incidents bypass the original ECDLP through nonces, validation failures, side channels, faults, or compromised artifacts. Such outcomes belong in the audit, but must not be mislabeled as solutions of the original ECDLP.

The machine-readable planning twin is `docs/ecdlp-audit/ECDLP_AUDIT_PLAN.mock.json`, validated against `ecdlp-audit-plan.schema.json`. The standalone verifier embeds that self-contained Draft 2020-12 schema and interprets every keyword it uses, including format checks; unknown schema features fail closed. It then applies stricter identity, provenance, path, dependency, obligation, and fail-closed mock-state invariants. It is deliberately marked `mock_non_authoritative`, has `promotion_allowed=false`, and contains no supported attack claim. The first execution evidence and exact cover/Jacobian boundary are recorded in `RESEARCH_ECDLP_AUDIT_EXECUTION_CHECKPOINT_20261014.md`.

Charter and claim boundary

Objective

Build the most comprehensive **publicly documented** audit of elliptic-curve private-key recovery in a frozen comparison set, while preserving exact identities, primary sources, negative evidence, costs, authorization, and independent review. "Most comprehensive in human history" remains an aspiration, not an auditable fact: private and unpublished audits cannot be enumerated. A future comparative claim must be dated, name the comparison set and metrics, expose every unknown, and survive independent denominator reproduction.

Exploration boundary

Executable work is limited by default to passive public evidence, public known-answer vectors, locally generated synthetic fixtures, and intentionally vulnerable local harnesses. Public visibility is not authorization to attack a system. Live probing, production exploitation, undeclared key recovery, credential use, exfiltration, and publication of usable secrets are outside this plan unless a separate written authorization record names the exact targets, techniques, window, rate and resource limits, data handling, disclosure path, and key-rotation procedure.

The authorization tiers are:

- **T0:** passive public literature, standards, source, binaries, and incident evidence.
- **T1:** local synthetic or toy fixtures with disposable known keys.

- **T2:** public challenge/test vectors only when their rules expressly authorize solving.
- **T3:** owned or third-party systems covered by a target-specific written authorization record.
- **T4:** live, third-party, or unclear-authority targets; passive public documentation only.

The default for this repository is `T0/T1`. Every executable receipt records its tier. Missing, expired, denied, or ambiguous authorization fails closed.

Outcomes are not interchangeable

Every assessment reports exactly one scoped outcome class:

- exact scalar recovery, independently checked by `[d]G = Q`;
- equivalent capability, such as forgery, decryption, or impersonation;
- partial secret leakage;
- property or provenance finding without recovery; or
- no recovery within an explicit family and budget.

A bounded failed search never proves universal nonexistence. An explicit cover never establishes subgroup preservation or an advantage. A stage speedup never establishes an end-to-end solver.

Requirements-to-evidence map

1. **Finish the present evidence gate.** The plan supplies catalog-replay, release, and dependency gates. Status is partial. Closure still requires full-checkout CI and Lean receipts, a fresh package, exact-artifact replay of 2,100 inputs, independent semantic replay, and required reviews.
2. **Close cover-transfer gaps.** The plan separates implementation tracks from the oracle/review gate. Status is partial. Closure still requires balanced two-infinity arithmetic, a catalog-general binary norm, all subgroup certificates, an independent divisor-class oracle, and exact non-solver language.
3. **Build a master audit ledger.** Exact-unit and revision rules, a schema mock, and coverage invariants exist as partial prerequisites; the ledger is absent. Closure requires a generated authoritative ledger, crosswalks, semantic verification, a frozen denominator, and migration receipts.
4. **Establish an evidence ladder.** Draft E0–E7 profiles and transition fixtures exist; the engine is absent. Closure requires a native transition validator, governed profiles, cross-record checks, and reviewer decisions.
5. **Sweep the complete attack taxonomy.** A 43-family candidate registry exists; its denominator is unfrozen. Closure requires a cited frozen route population, exact cells and controls, and evidence or obligations for every frozen cell.
6. **Build the literature and incident corpus.** A draft protocol and pointer-only seed exist; no search has run. Closure requires a deduplicated, hash-addressed primary corpus, claims, errata/retractions, public incidents, and a comparator matrix.
7. **Standardize experimental accounting.** A draft common cost contract and synthetic fixtures exist; the native checker is absent. Closure requires adapters, arithmetic reconciliation, and independently replayed real receipts.
8. **Add independent governance.** Draft role separation, policy, and drills exist but are not approved. Closure requires protected decisions, authenticated roles, verified release integration, and an external replication registry.

The plan is complete as a planning artifact only when its schema, mock, diagram, links, and validation pass. None of rows 1–8 is marked `verified_complete` merely because this document exists.

Canonical unit and additive history

The denominator is not "one curve." The audit unit is:

```
curve model × representation × subgroup × protocol role ×
implementation revision × attack route × adversary model
```

The unit identity is stable across evidence corrections. A separate assessment identity adds the evidence-set revision, evaluator version, and scoped claim results. Old assessments are immutable and a correction creates a

new assessment linked by `supersedes`.

Full EC1/ICV1 and content-addressed identifiers are join keys; names and short digests are display aids. Implementation identity binds repository, commit, dirty state, executable hash, build manifest, configuration, and version. A dirty build needs a tree digest and cannot support promotion without an explicit reviewed exception.

Existing systems remain authoritative for their own domains:

- The curve registry and identity rules supply models, representations, and exact joins. They do not establish protocol deployment or attack status.
- The cover-transfer ledger supplies 2,100 classified maps and 664 subgroup contexts. It does not establish complete arithmetic, transfer, a solver, or an advantage.
- The IC boundary ledger supplies fail-closed solver-stage and matched-rho accounting. It does not establish non-IC routes or universal coverage.
- The weak-family catalogue supplies structural families and cited applicability leads. It does not establish incident, implementation, or protocol completeness.
- The attack matrix supplies a taxonomy seed and historical implementation pointers. It does not establish a canonical denominator or evidence maturity.

Attack taxonomy and anti-double-count rule

Routes are assigned through this decision order:

1. If the route computes the scalar from the public group instance while remaining in the same target group/problem representation, it is lane A.
2. If it transports the target subgroup into another algebraic object, solves or reasons there, and recovers the source result, it is lane B.
3. If it establishes a special parameter property or generation/provenance condition, it is lane C. Its exploitation is a separate linked A/B record.
4. If it depends on nonce/RNG leakage, malformed inputs, observations, faults, protocol oracles, memory, or operational exposure and leaves the original DLP unsolved, it is lane D.
5. If it changes trust in identity, sources, artifacts, measurements, or delivery, it is lane E. Direct leakage is represented by a linked D record.

Hybrid routes form a typed directed acyclic graph and inherit their weakest unresolved obligation. They are not flattened or counted twice. For example, "supersingular" is a lane-C property and MOV is its lane-B exploitation; nonce-lattice recovery is lane D, not a true ECDLP solution.

- **Lane A — true ECDLP:** exhaustive/BSGS; rho/lambda and parallel variants; automorphism or hardware accelerators; native relation/index-calculus methods; auxiliary-input and interval methods; quantum algorithms and separately scoped resource estimates.
- **Lane B — mathematical transfer:** MOV/Frey–Rück; anomalous or p-adic lifts; Weil/GHS descent and restriction of scalars; isomorphisms, twists, models, isogenies, and fields; covers and Jacobian correspondences; explicit embeddings or quotients.
- **Lane C — parameter asymmetry:** order, cofactor, smoothness, trace, embedding degree, supersingularity, CM/endomorphism structure, seeds, unexplained filtering, retained trapdoor witnesses, downgrade, and catalog errors.
- **Lane D — protocol/implementation bypass:** nonce reuse/bias/HNP, RNG/key generation, invalid-curve/twist/cofactor checks, timing/cache/EM/power, faults, protocol oracles, arithmetic/parser/memory/state bugs, and logs/backups/HSM/firmware exposure.
- **Lane E — evidence/supply chain:** provenance, identity confusion, source/release/binary/toolchain mismatch, accounting defects, circular verification, dataset custody, dependency/build/firmware compromise, incident attribution, survivorship bias, and correction governance.

Claim status, evidence maturity, and independence

Claim status and evidence maturity are orthogonal.

Claim status	Meaning
`supported`	The exact scoped proposition has all profile-required evidence.
`refuted`	A cited counterexample, proof, or incompatibility refutes that exact proposition.
`unknown`	Required evidence is absent, inconclusive, stale, or bounded below the proposition.
`not_applicable`	A checked precondition fails for the exact unit; the reason is explicit.

No blank state is allowed. `Unknown` counts toward classification coverage but never toward scientific resolution or safety.

- **E0:** registered with exact subject identity, owner, scope, and authorization tier.
- **E1:** primary source, falsifiable claim, hypotheses, threat model, and provenance pinned.
- **E2:** applicability and exact invariants independently checked; negative language bounded.
- **E3:** mechanism or construction reproduced on public synthetic or known-answer fixtures with exact hashes and negative tests.
- **E4:** claimed mathematical or protocol effect certified on its domain, including exceptional cases and subgroup/recovery obligations where applicable.
- **E5:** independent replay plus a separate implementation/oracle where feasible, with reproducible artifact identity.
- **E6:** complete costs and matched controls on the identical workload, with cold, online, and amortized boundaries separate.
- **E7:** independently replicated end-to-end output verification on a second host/toolchain or implementation, with holdouts/scaling appropriate to the claim and exact non-claims.

The level is derived as the highest **contiguous** satisfied set of required gates. A high maturity level cannot turn an `unknown` claim into `supported`. The effective maturity of a composed route is the minimum of its required components.

Independence is also explicit: R0 self-check; R1 fresh-process same-artifact replay; R2 independent oracle/differential implementation; R3 a separate reviewer reconstructs the claim; R4 a second host/toolchain; R5 external public replication. E5 needs at least R2+R3, E6 needs R3+R4, and E7 needs R4 and preferably R5. A same-author rerun is isolation, not independent review.

Common experimental accounting

Measured, modeled, and extrapolated quantities are never mixed. The cold one-target cost is recorded phase by phase:

```
C_cold(1) = route reconstruction + parameter validation + construction/search
          + reusable setup + acquisition/queries + conversion/transfer
          + core solve + relation linear algebra/postprocessing
          + recovery + independent verification.
```

Failed searches, duplicates, rejected outputs, timeouts, OOMs, query counts, retained bytes, peak/area memory, I/O, parallelism, hardware, seeds, uncertainty, and success probability are part of the record. Unknown is `null`, never zero.

The repository's target-dependent one-target online interval is retained as a separate primary view. An amortized number `C_amortized(N)=C_reusable_setup/N+mean(C_per_target)` is admissible only when the exact setup is genuinely reusable; `N` and cold cost appear first. A speedup needs the same public target, accounting boundary, environment, and resource envelope; it cannot be assembled from the best components of different runs. CPU wall-time claims also require A/A noise, paired controls, a host-isolation receipt, and an appropriate uncertainty interval.

Dependency plan

```
M0 scope, authorization, identity, and denominator freeze
 +-- M1 current cover release gate (WS1)
 \-- M2 audit contracts (WS3 + WS4 + WS7 + WS8)
       +-- M3 source corpus (WS6) --> taxonomy coverage (WS5)
       \-- M4 cover-transfer implementations (WS2)
M1 + M2 + M3 + M4 --> M5 bounded route-by-route audits
M5 --> M6 independent replication and review
M6 --> M7 dated comparative comprehensiveness report
```

WS8 governs promotion throughout; it is not a final rubber stamp. The rendered dependency diagram is a visual twin of this sequence.

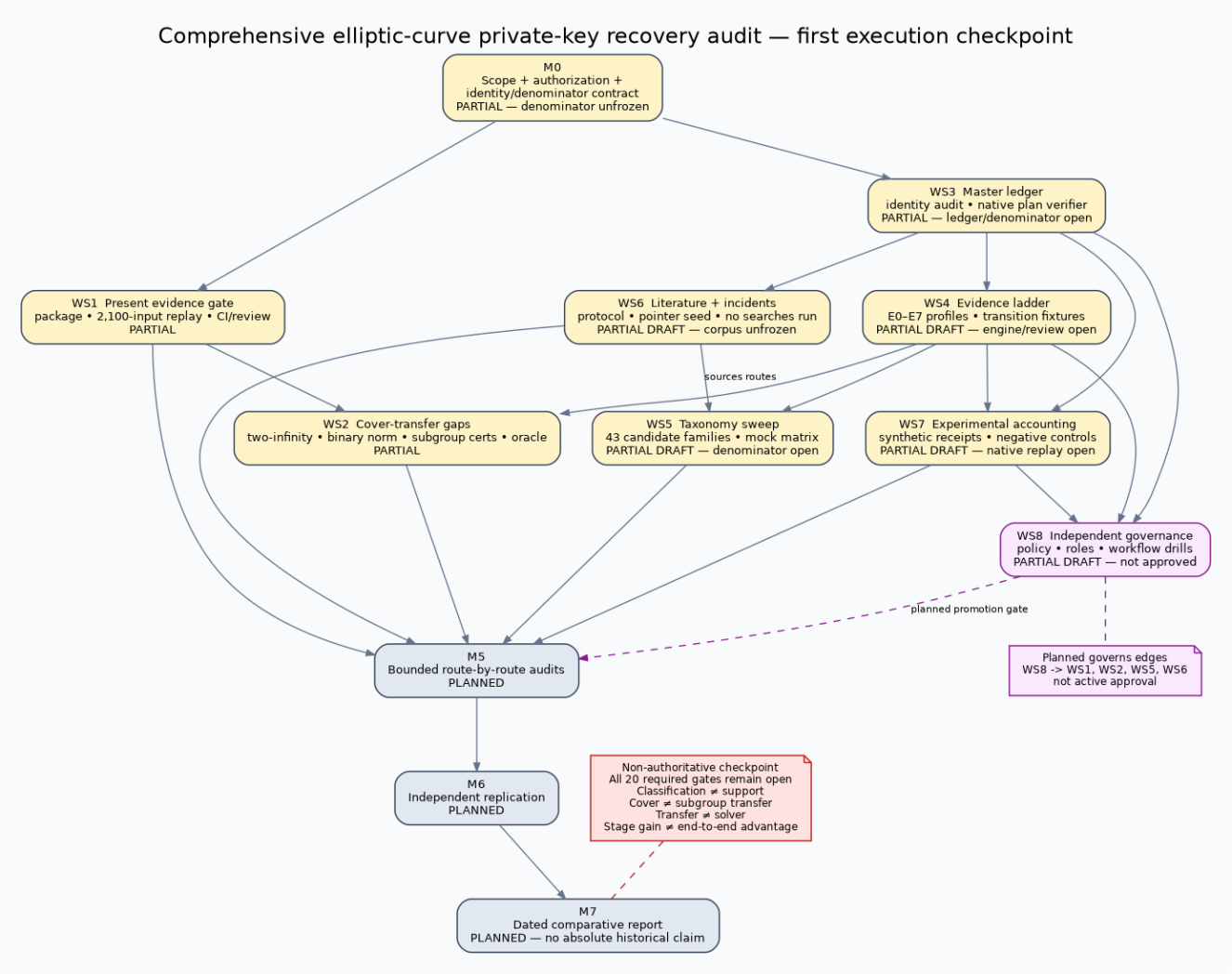


Figure 1: Eight-workstream dependency graph. Yellow nodes are partial work, purple is draft independent governance, and gray nodes are planned later execution/replication/reporting milestones. Dashed purple edges are planned governance, not active approval.

Workstream 1 — finish the present cover evidence gate

Current state: partial. The current assessment classifies all 2,100 map rows and all 664 EC1 bindings. Classification is not blanket support. The current-source constructor accepts the catalog, while the published artifact was

replayed only on its bundled 592-row registry.

Deliverables and exit gates:

1. Freeze the full-checkout commit, registries, schemas, build inputs, and CI workflow revisions.
2. Obtain full CI, Lean kernel/axiom audit, and semantic-replay receipts.
3. Build a fresh standalone artifact and record source, binary, dependency, toolchain, configuration, and SBOM hashes.
4. Replay all 2,100 cover inputs against that **exact artifact**, retaining unsupported results, failures, runtime, memory, and commands.
5. Reconcile crypto and cryptanalysis identities and results.
6. Obtain mathematical, implementation, and evidence/replay review.

Exit requires every identity and count to reproduce and all mandatory reviews and CI gates to pass. It adds no Jacobian solver or speedup claim.

Workstream 2 — close the cover-transfer gaps

This is multiple implementation PRs, not a single "complete covers" label.

WS2A: balanced two-infinity odd-characteristic Jacobians

Implement validity, canonical representation/reduction, equality, negation, addition, scalar multiplication, both infinity classes, pullback, and arbitrary norm for the 1,940 odd-characteristic catalog covers. Start with exhaustive public fixtures over `p <= 31`, then small extensions, then catalog replay. Exit requires an independent oracle, malformed and exceptional cases, representative independence, additivity, and `phi_* phi^* = [2]` on the stated domain.

WS2B: arbitrary binary Jacobian norm

Implement the norm for every valid reduced genus-three class in the supported one-infinity model, including nonsplit/repeated support and exceptional fibers. Start with exhaustive `GF(2^3)` fixtures. Exit requires independently enumerated results, shared-support tests, homomorphism checks, and the public general path verifying `phi_* phi^* = [3]`, plus a current-revision mirror or integration receipt from aburan28/cryptanalysis and exact EC1/ICV1/HC1/CV1 bindings for the positive fixture and supported catalog rows.

The first bounded implementation slice now handles all 486 classes of the exact polynomial-basis F8 fixture with `a=1`, `b=3`. Its native test checks all 236,196 ordered additivity pairs, rational-point agreement, all six target pull-push cases, equal kernel fibers, and explicit exceptional and nonsplit classes. A separate native implementation now exhaustively counts the source over `GF(8)`, `GF(8^2)`, and `GF(8^3)` as `6`, `104`, and `558`, reconstructs the zeta numerator, and replays the machine-readable certificate for `#Jac(H)(GF(8))=486`. That order certificate does not check the 486 representatives, group law, `A/B` presentation, norm, or transfer identities. The transfer remains local same-implementation evidence, every other binary model returns structured `unsupported`, and WS2B remains open for the catalog-general path. The retained cryptanalysis parity receipt predates this fixed-fixture norm, so current cross-repository parity is also open.

WS2C: subgroup certificates

For all 664 EC1 bindings, bind exact order/factor certificates, generator membership, nonzero image, exact image order, kernel intersection, composition, and degree-inverse recovery. A generator-only check is not an all-element homomorphism or injectivity proof.

WS2D: independent reference

Build or pin a mathematically independent Sage/Magma/separate-code oracle. It must not share the implementation logic it is meant to check. Unavailable commercial tooling is recorded as a blocker, not silently replaced by a circular test. The fixed-F8 extension-count replay discharges only the Jacobian-cardinality subclaim; an independent divisor-class and transfer oracle is still required.

None of WS2A–D establishes a faster destination solver. A full Jacobian index-calculus solver remains a separate deliverable.

Workstream 3 — build the master audit ledger

Deliver a versioned authoritative schema, generated additive ledger, EC1/ICV1 and specialist-ledger crosswalks, membership hashes, semantic verifier, migration record, and dashboard. Freeze and hash the denominator before reporting coverage.

Exit gates:

- every frozen unit has exactly one latest assessment and immutable history;
- every required claim cell is `supported`, `refuted`, `unknown`, or `not_applicable` with rationale and evidence/obligation as appropriate;
- conflicting identities, orphan evidence, missing population members, duplicate latest revisions, or status without evidence fail closed;
- protocol and implementation inventories are explicit rather than inferred from curve catalogs; and
- machine totals and human tables reproduce from the same source.

Workstream 4 — enforce the evidence ladder

Define route-specific profiles over E0–E7 and machine-enforce legal contiguous transitions. Deliver promotion, rejection, demotion, stale-evidence, and additive-correction fixtures. Existence, arithmetic, subgroup preservation, end-to-end recovery, cost advantage, and scaling are separate obligations.

Exit requires a transition validator and review rule that propagate the weakest unresolved obligation through composed routes. Formal proof and computational certification requirements must be explicit per claim; neither is silently substituted for the other.

Workstream 5 — sweep the frozen attack taxonomy

For every route in lanes A–E, record prerequisites, affected exact identities, protocol/implementation versions, adversary access, authorization tier, primary sources, claim status, evidence level, controls, costs, and open obligations. Use public known-answer curves, synthetic signatures, and local vulnerable harnesses only by default.

Exit requires zero blank cells in the frozen population and a versioned route registry. “Not found” remains bounded to the searched family, date, method, and budget. Proprietary evidence and platform-specific side-channel facilities may remain explicit `unknown`/`blocked` entries without being called safe.

Workstream 6 — build the literature and incident corpus

Create a hash-addressed manifest of primary papers, errata, retractions, code, standards, advisories, and public incident reports. Each source records stable identifier/URL, authors, date, exact page/section or code revision, retrieval date, content hash where lawful, license/archive status, supersession, claims, hypotheses, affected identities, and chain of custody.

The search protocol freezes databases, queries, dates, inclusion/exclusion rules, languages, deduplication, and backward/forward citation passes. Compare coverage against frozen versions of SafeCurves, ECRYPT/ENISA guidance, major bibliographies, standards, and public vulnerability/advisory corpora.

Exit requires critical claims to have primary sources and second-person verification, with unavailable/paywalled evidence recorded rather than inferred. A future comprehensiveness claim is permitted only after publishing this corpus and comparator matrix.

Workstream 7 — standardize experimental accounting

Generalize the existing IC measurement discipline to transfers, parameter searches, protocol attacks, side channels, faults, artifact studies, and incident reproductions. Deliver a common run schema, claim checker, migration adapters, and golden valid/invalid receipts.

Exit requires rejection of missing intervals, mixed denominators, mismatched targets, hidden preprocessing, unreported failures, and synthetic composite speedups. Raw evidence is immutable and replayable. Native counters remain in their native units until a measured conversion is supplied.

Workstream 8 — add independent governance

Roles are author, mathematical reviewer, implementation reviewer, evidence/replay reviewer, authorization/privacy reviewer when needed, and release approver. Significant claims cannot be self-promoted. A reviewer records identity, independence relationship, conflicts, reviewed revisions, decision, and evidence receipt.

Deliver a governance policy, review templates, CODEOWNERS/review matrix, promotion/demotion and correction procedure, evidence expiry/recheck policy, decision log, release checklist, and external replication registry. Exercise one mock promotion, rejection, demotion, and additive correction before the workflow is relied upon.

Exit requires auditable human decisions plus machine gates; CI breadth alone is not independent review. Frozen evidence is never rewritten.

Solver acceptance remains separate

A full Jacobian index-calculus solver can be assessed under this program, but is not delivered by the cover work or this plan. Its acceptance profile must require:

- actual verified Jacobian relations, not elliptic norm projection;
- frozen factor base and target identities;
- relation yield including failed searches and duplicates;
- verified matrix construction, rank, linear algebra, and target decomposition;
- independent recovery and verification of the known scalar;
- a blind-custody run in which the solver receives only the public group, public source/target classes, subgroup order, and declared parameters while the verifier withholds the scalar until after the committed output, plus a negative control showing that no fixture, log, cache, or environment path leaks that witness;
- explicit supported parameters and infinity/Jacobian models;
- cold, preprocessing, online, recovery, verification, memory, hardware, seed, timeout, OOM, and total-runtime accounting;
- a strong matched generic baseline on the identical public target; and
- independent replay and implementation/oracle checks appropriate to E7.

Elliptic norm projection is a transfer component, not that solver.

Dashboard and completion rules

No single percentage may collapse inventory, classification, evidence, authorization, and governance. The dated dashboard reports at least:

- taxonomy cells classified / frozen cells;
- exact audit units present / denominator units;
- sources retrieved and audited / enumerated sources, split by paper, standard, code, advisory, and incident;
- claim counts by status and E0–E7 maturity;
- independent reproductions / executable claims;
- complete-cost records / claims making cost or impact assertions;
- exact identity/version bindings / records;
- unresolved, blocked, stale, and overdue obligations;
- retained observed failures / total observed failures;

- reviewer-role coverage, conflicts, and correction latency; and
- authorization-documented execution units / executable units.

"Classification complete" permits explicit unknowns. "Scientifically resolved" does not. "Promotion ready" requires every mandatory gate, review, authorization, and evidence reference for the exact claim profile.

The final comparative report may say "most comprehensive publicly documented audit in comparison set X as of date Y by metrics Z" only if the frozen corpus and denominators are reproducible, all in-scope cells are classified, unknowns remain visible, and an independent reviewer reproduces the comparison. It may not claim unqualified historical completeness.

Immediate sequence and update procedure

1. Land this charter, schema mock, validator, diagram, PDF, and index links.
2. Close WS1 or retain its blockers verbatim; do not let it block the schema and corpus contracts.
3. Turn the mock into a versioned authoritative ledger only after WS3 and WS8 identity/governance review. The mock itself can never promote claims.
4. Freeze the WS6 search protocol and initial corpus; then freeze the WS5 route denominator.
5. Execute WS2A–D as separately reviewable implementation/evidence changes.
6. Run bounded route audits, independent replication, and only then the dated comparative analysis.

Every update changes the human plan and machine twin together, runs `cargo run --release --bin ecdlp-audit -- verify-plan --input docs/ecdlp-audit/ECDLP_AUDIT_PLAN.mock.json --repo-root .`, renders the dependency graph and PDF, records a changelog entry, and names what remains unknown. Corrections are additive; old evidence stays addressable.

Current non-claims

- The eight workstreams have not all been executed.
- The repository has not proved a literal "most comprehensive in history" claim.
- Catalog classification does not imply arithmetic or exploit support.
- No production target, third-party key, or live service was tested.
- No new practical ECDLP speedup or full Jacobian solver is claimed.
- No parameter-generation irregularity is attributed to malicious intent without an explicit witness and independently verified exploit chain.

Changelog

- **2026-10-13 — planning artifact only.** Initial charter, eight-workstream plan, taxonomy, evidence/accounting contract, governance gates, and non-authoritative machine mock.
- **2026-10-14 — partial execution; all 20 required gates remain open.** Native planning validator; exact WS1/WS2 boundary audit; WS3 identity audit; draft WS4–WS8 contracts and fixtures; execution checkpoint and visual.